

07

BOOK 07 / 08

안전한 설계와 실패 처리

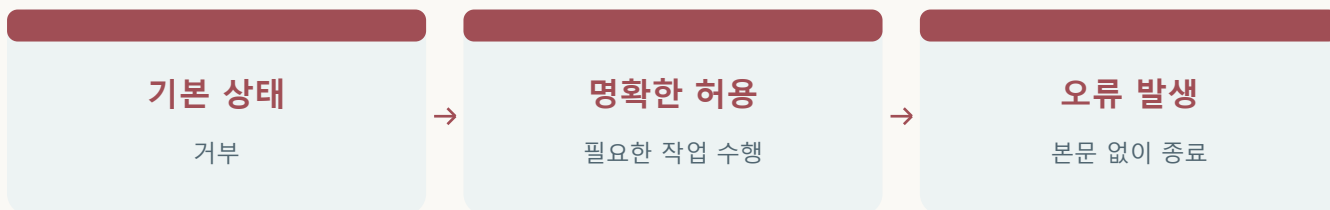
실패해도 보호 조건은 유지되어야 한다

개념 이해 / 사례 읽기 / 확인 문제 약 15분

비공개 학습 노트 서비스를 따라 배우는 보안의 기본

이 책을 읽는 방법

확인하지 못한 권한을 허용으로 바꾸지 않습니다.



읽기 순서

학습 목표와 선수 지식	3
시작 상황: 권한 서버가 고장 나면 일단 보여 줄까?	3
개념 설명	3
흐름 비교	3
실패를 숨기는 것과 처리하는 것의 차이	4
개발·검수 시 확인사항	4
핵심 요약	4
확인 문제	5
정답과 해설	6
다음 학습과 출처	6

사례를 먼저 읽고, 개념과 코드의 차이를 확인한 뒤 문제를 풀어 보세요. 정답과 해설은 문제 다음 페이지에서 시작합니다.

공통 사례 / 비공개 학습 노트

민서(사용자 101)의 노트는 10번, 준호(202)의 노트는 20번입니다. 모든 노트는 비공개이며, 로그인한 소유자만 조회·수정할 수 있습니다. 제목은 1~80자의 일반 텍스트입니다.

비밀번호·세션 토큰은 로그에 남기지 않고, 권한을 확인할 수 없으면 본문을 보내지 않습니다. 이 가상 서비스의 예제는 학습용 축약본이며 실제 서비스의 계정·데이터 구현과 무관합니다.

학습 목표와 선수 지식

인증·인가와 오류 응답의 의미를 이해했다고 가정합니다. 학습 후에는 최소 권한·기본 거부·다층 방어를 사례로 설명하고, 권한 확인 실패를 접근 허용으로 처리하면 안 되는 이유를 말할 수 있습니다.

시작 상황: 권한 서버가 고장 나면 일단 보여 줄까?

노트 소유자를 확인하는 과정에서 DB 오류가 발생했습니다. 개발자가 사용자의 불편을 줄이려고 오류가 나면 본문을 보여 주도록 처리했습니다. 하지만 '권한이 있음을 확인했다'와 '권한 확인을 끝내지 못했다'는 다른 상태입니다.

개념 설명

원칙	의미	노트 서비스에 적용
최소 권한	필요한 대상과 작업에 필요한 만큼만 허용	조회 전용 작업에 전체 DB 삭제 권한을 주지 않음
기본 거부	허용 조건이 충족된 경우에만 허용	소유자라는 근거가 없으면 본문을 반환하지 않음
다층 방어	서로 다른 단계의 조치로 실패 가능성과 영향을 줄임	인가 검사와 제한된 DB 계정 권한을 함께 적용
안전한 실패	실패 경로에서도 보호 조건을 유지	인가 확인 중 오류가 발생하면 비공개 본문 제공 중단

다층 방어는 같은 검사를 의미 없이 여러 번 붙이는 일이 아닙니다. 인가 검사는 누가 어떤 노트를 볼지 결정하고, DB 계정의 권한 제한은 잘못된 질의가 수행할 수 있는 작업 범위를 줄입니다. 역할이 다릅니다.

흐름 비교

다음은 의사코드입니다.

PSEUDOCODE / 흐름 읽기

문제가 있는 흐름:

권한 확인을 시도한다
 권한 확인 중 오류가 발생하면 허용으로 간주한다
 허용이면 비공개 본문을 반환한다

개선한 흐름:

권한 확인을 시도한다
 허용 결과가 명확한 경우에만 본문을 반환한다
 거부 결과이면 접근 거부 정책에 따라 응답한다
 확인 중 오류가 발생하면 본문 없이 일시적 처리 실패를 응답한다
 내부에는 민감정보를 제외한 오류 유형과 추적 ID를 기록한다

권한이 없는 경우와 시스템이 고장 난 경우는 모두 본문을 보내지 않지만 운영상 의미는 다릅니다. 내부 기록에서는 구분해야 문제를 진단할 수 있습니다. 사용자에게는 내부 SQL-서버 경로·스택 추적을 그대로 보여 주지 않습니다.

실패를 숨기는 것과 처리하는 것의 차이

모든 예외를 잡고 성공 메시지를 보내면 화면은 조용해지지만 데이터가 저장되지 않았을 수 있습니다. 안전한 실패에는 성공 여부를 정확하게 알리는 것도 포함됩니다. 여러 데이터를 함께 변경하는 작업이라면 중간 실패 시 일부만 저장되지 않도록 트랜잭션과 복구 정책을 검토해야 합니다.

이 과정의 '안전한 실패'는 비공개 노트의 보호 조건에 관한 것입니다. 모든 시스템의 모든 기능을 무조건 중단하라는 뜻은 아닙니다. 실패 시 허용할 대체 동작은 자산과 요구사항에 맞게 미리 정해야 합니다.

개발·검수 시 확인사항

정상 요청 외에 인증 만료, 없는 노트, 권한 없음, DB 오류를 각각 확인합니다. 오류 때 보호 조건을 우회하는 기본값이나 과도한 권한이 생기지 않는지 살펴봅니다. 민감한 작업에서는 재시도로 중복 변경이 발생하는지도 후속 설계에서 확인합니다.

핵심 요약

- '권한 확인 실패'는 '권한 확인 성공'이 아닙니다.
- 예외를 감추는 것만으로 오류를 처리한 것은 아닙니다.
- 사용자 응답과 내부 진단 기록은 목적과 포함 정보를 구분합니다.

확인 문제

1. 권한 DB에 연결할 수 없을 때 임시로 모든 노트 조회를 허용하는 처리는 어떤 보호 조건을 깨뜨릴까요?

2. 예외를 잡은 뒤 항상 '저장 성공'을 반환하면 어떤 문제가 생길까요?

3. 오류 로그를 없애면 정보 노출과 운영 문제를 모두 해결할 수 있을까요?

정답과 해설

1. 소유자임을 확인한 경우에만 본문을 제공한다는 조건을 깨뜨립니다. 가용성 문제를 줄이려다 기밀성 위험을 만듭니다.
2. 실제 저장 결과와 안내가 달라집니다. 사용자 판단을 잘못 이끌고 실패를 탐지하기 어렵게 합니다.
3. 아닙니다. 필요한 진단 근거가 사라집니다. 민감정보를 줄이고 필요한 사건·결과·추적 정보를 적절한 권한으로 관리해야 합니다.

다음 학습과 출처

최소 권한과 기본 거부: [OWASP Authorization](#). 오류 응답과 내부 처리: [OWASP Error Handling](#). 다음 단원에서는 학습한 질문을 하나의 흐름에 적용합니다.

나의 한 문장

이 강의에서 배운 내용을 동료에게 설명한다면 어떻게 말할까요?
